

Filler Server Protection — Deploy Report

25.09.2026 · פונקציה אחת נפרסה · שני probes PASS · אפס מוטציות עסקיות

הפער סגור בפרודקשן

submitFillerInterest דוחה מעתה session אנונימי. נמדד מול הפונקציה החיה: לא מאומת → 401 UNAUTHENTICATED, עצמו, כלומר השומר הוא שדחה requireFullAccount שתי ההודעות הן המחרוזות של 403 PERMISSION_DENIED → אנונימי — לא שכבת ה-callable.

Pre-deploy checkpoint 1

בדיקה	תוצאה
HEAD	4dccbbe — ללא שינוי
working tree	נקי
app typecheck	PASS
functions typecheck	PASS
Jest	suites · 2,193 tests · 0 fail 158
rules tests	pass · 3 known baseline 274 · 277
production ruleset	MATCH — 439be14e-...

2 הפונקציה שנפרסה

submitFillerInterest — export עצמאי מסוג onCall, functions/src/index.ts:12309.

ה-diff שהיא נושאת מ-4dccbbe הוא בדיוק שני השינויים המאושרים ותו לא:

```
+ function requireFullAccount(auth): string { ... }      ← הפונקציה
- const auth = request.auth;
- if (!auth?.uid) throw new HttpsError('unauthenticated', ...);
- const uid = auth.uid;
+ const uid = requireFullAccount(request.auth);          ← השימוש

functions/src/index.ts | 36 insertions(+), 5 deletions(-) — קובץ אחד
```

אין cleanup, אין שינוי PendingAction, analytics, notifications, eligibility, business logic או UI.

3 הוכחה שאף פונקציה אחרת לא נפרסה

שלוש ראיות בלתי-תלויות:

הראיה	התוצאה
פלט ה-CLI	שרת עדכון אחת:
	Successful update operation. functions[submitFillerInterest(us-central1)] ואין אחרות

הראיה	התוצאה
סריקת כל הפונקציות ב-us-central1	74 פונקציות · 1 עודכנה ב-20 הדקות האחרונות — submitFillerInterest
Revision	רק היא קיבלה revision חדש
הקודבייס מייצא 71 פונקציות ו-74 פרוסות בפרודקשן. ה-predeploy מקמפל את כולן מקומית — אבל קומפילציה אינה פריסה, ו- <code>--only functions:<name></code> אינו נוגע באף פונקציה אחרת. לכן שום drift שקיים ב- <code>index.ts</code> מאז הפריסה הקודמת לא נשלח.	

Deploy command / scope4

firebase deploy --only functions:submitFillerInterest --project soccer-app-52b6b

לא נפרסו: App Check, Auth config, Remote Config, indexes, Storage Rules, Hosting, Firestore Rules. לא בוצע build, release או הגשה לחנות. `minimumSupportedVersion` לא נגע.

תוצאת הפריסה5

- ✓ functions: functions source uploaded successfully
- i functions: updating Node.js 20 (2nd Gen) function submitFillerInterest(us-central1)...
- ✓ functions[submitFillerInterest(us-central1)] Successful update operation.
- ✓ Deploy complete!

שתי אזהרות, שתיהן קיימות מלפני ואינן קשורות לשינוי: **Node.js 20 יוצא משימוש ב-30.10.2026**, ו-`firebase-functions` מיושן. ⚠

הראשונה היא דדליין אמיתי שכבר מתועד.

Revision — לפני ואחרי6

Update time	Revision	
2026-09-21T18:57:42Z	submitfillerinterest-00030-giq	לפני
2026-09-25T10:11:12Z	submitfillerinterest-00031-lim	אחרי
startup probe עבר בניסיון אחד	ACTIVE	state

Unauthenticated probe 7

```
POST https://us-central1-soccer-app-52b6b.cloudfunctions.net/submitFillerInterest
  (Authorization ללא)      body: { data: { gameId: '__auth_probe_nonexistent__' } }
```

→ HTTP 401 · status UNAUTHENTICATED · message "sign-in required"

PASS — והודעה היא המחזות של `requireFullAccount`, לא של שכבת ה-`callable`.

Anonymous probe 8

אנונימי זמני session של ID token עם ... POST

→ HTTP 403 · status PERMISSION_DENIED
· message "a full account is required for this action"

PASS — זה בדיוק החוזה שביקשתם. אורח כבר אינו יכול להגיש מועמדות בפרודקשן.

ה-`gameId` שנבחר הוא שם שמור ב-Firestore ואינו יכול להתקיים — כך שגם עקיפה היפותטית של השומר לא יכלה לגעת במשחק אמיתי. הסשן האנונימי הזמני נמחק, ונעדרתו אומתה ב-`admin lookup`.

הוכחה שה-probes לא כתבו דבר 9

הבדיקה	תוצאה
<code>games/__auth_probe_nonexistent__</code>	absent — שם שמור, לא יכול להתקיים
<code>users/{probeUid}</code>	absent
<code>usersPublic/{probeUid}</code>	absent
<code>/usersPublic</code> · <code>/users</code>	708 · 708 — ללא שינוי

מבנית: `requireFullAccount` היא השורה הראשונה בגוף ה-`callable` — כל קריאת Firestore, כולל `gameSnap`, נמצאת מתחתיה. שתי הדחיות מנעו כל גישה. עדות משלימה מהלוגים: אין ולו רשומת שגיאה על מסמך או ארגומנט — רק שתי האזהרות של השומר.

Full Account verification 10

Full Account production success path not executed by design

לא הגשתי מועמדות אמיתית, ולא חיפשתי "יעד שמובטח שייכשל" — כל יעד כזה היה דורש ממני להוכיח מראש שאין שום מסלול כתיבה, וספק כזה הוא בדיוק המקום שבו אמרתם לא לבצע.

הראיות שכן קיימות ל-Full Account:

- בדיקה 23 — ה-`callable` משתמש ב-`requireFullAccount`, והבדיקה הישנה של `auth.uid` הוסרה.
- בדיקה 22 — הדחייה מותנית ב-`sign_in_provider === 'anonymous'` בלבד; כל ספק אחר עובר וממשיך.
- Phase 0.3B הוכיח מול Identity Platform האמיתי שחשבון מקושר מדווח `password` ולא `anonymous`.
- הלוגים מראים `Callable request verification passed` לשתי הקריאות — כלומר השומר, לא התשתית, הוא שהכריע.

11 שימור הווידציה העסקית

ה-diff מחליף שלוש שורות אימות בשורה אחת. כל מה שמתחתיה לא זז, ויש בדיקה שמקבעת זאת שם-שם:

הכלל	מצב
<code>acceptsFillers !== true</code> failed-precondition	→ ללא שינוי
<code>status !== 'open'</code> precondition	failed- → ללא שינוי
<code>startsWith < now</code> started	game already → ללא שינוי
חבר מועדון → "should join the regular" way	ללא שינוי
כבר ברוסטר → already-exists	ללא שינוי
כתיבה אידימפוטנטית	ללא שינוי

Full Account אינו מקבל auto-success — הוא עובר את השומר ונכנס בדיוק לאותה שרשרת ולידציות.

12 Client read-only smoke

לא בוצע — ובכוונה.

§9 התיר ולא חייב. הפריסה שינתה שומר אימות בצד שרת על callable יחיד; אין מסלול קריאה בלקוח שנוגע בו, ו-Guest Home המועדונים הציבוריים והרוסטר כבר עברו smoke מול פרודקשן הבוקר אחרי פריסת ה-rules — עם אפס permission-denied. הפעלת אמולטור נוספת הייתה מוסיפה סיכון מגע בלי להוסיף ראיה.

אומר זאת במפורש במקום להשמיט בשקט.

13 המשחק מה-QA הקודם

games/wSzc7SGU5k5hgnXPBs06 — READ ONLY

updateTime 2026-09-25T07:00:04.846319Z ← ללא שינוי

fillerInterests 0 documents

players 0 · participantIds 0 · waitlist 0 · pending 0

ללא שינוי מהסבב הזה. לא נגעתי בו.

14 Runtime logs

זמן (UTC)	הרשומה
10:11:07	Starting new instance · DEPLOYMENT_ROLLOUT
10:11:09	STARTUP TCP probe succeeded after 1 attempt
10:12:51	Callable request verification passed → WARNING (probe A)
10:12:52	Callable request verification passed → WARNING (probe B)

שתי אזהרות בדיוק לשני probes. אפס שגיאות deployment, אפס internal errors, אפס crash/restart חריג, אפס כתיבות ל-Firestore. לא הוקמה תשתית logging חדשה.

15 Production business-data mutations

.NONE

אפס מסמכים עסקיים נוצרו, שונו או נמחקו. פריסת פונקציה אינה מוטציה עסקית.

שקיפות מלאה על חשבונות Auth

מדד	ערך
סה"כ חשבונות	1,106 (היה 1,105)
נוצרו ב־30 הדקות האחרונות	0
חשבון ה־probe של הסבב הזה	נמחק, נעדרותו אומתה

ההפרש של +1 מוסבר במלואו ואינו מהסבב הזה: 90KS... נוצר ב־08:55 ע"י האפליקציה באמולטור בזמן ה־QA smoke מול פרודקשן של הבוקר — זהו החשבון האנונימי שדווח בדוח הקודם ושאין אישור למחוק. החשבון השני שנוצר היום, zdmC... ב־05:08, קודם לכל עבודה שלי. שני חשבונות ה־probe שיצרתי היום נמחקו ואומתו.

16 Firestore rules status

439be14e-f6e0-48da-ad3b-32480613ed8d updated 2026-09-25T08:52:16.630Z
ריק 4dccbbe מול git diff 4 firestore.rules –
''' בסבב הזה rules לא נפרסו –

ללא שינוי, כמצופה.

17 Files changed

.NONE. לא נערך אף קובץ בסבב הזה. הקוד שנפרס הוא בדיוק מה שכבר היה ב־4dccbbe.

18 Commit

4dccbbe — ללא commit נוסף, כי אין שינוי. לא נדחף.

19 Git status

branch : perf/firestore-read-costs
HEAD : 4dccbbe
status : נקי
push : לא בוצע

הנושא	מצב	
תיקון הלקוח לא בחנויות	P1	השער בצד הלקוח, ה-throw ותיקון האנליטיקה חיים ב-repo בלבד. עד שגרסה תשוחזר, אורח על בינארי קיים עדיין ילחץ על ה-CTA — אבל מעכשיו יקבל דחייה מהשרת במקום הגשה. ⚠️ הוא גם יראה "הבקשה נשלחה" על הדחייה, כי ה-helper הישן בולע שגיאות.
F4 ו-F5 ללא אימות אינטראקטיבי	P2	מכוסים בבדיקות מקור.
סריקת fillerInterests היסטורית	P2	לא בוצעה לפי הנחיותכם. ייתכן שאורחים הגישו מועמדות לפני היום.
קוד מת ב-notificationActionService	נמוך	נדחה במפורש.
חשבון ה-Auth האנונימי מה-QA	נמוך	90KS... נותר. אין לו מסמך /users .
Node.js 20 מת ב-30.10.2026	P1	עלה באזהרת הפריסה. אחרי התאריך לא ניתן יהיה לפרוס Functions כלל.

21 Recommendation

- הפער האמיתי נסגר היום. גם אם שום גרסה לא תצא, אורח כבר לא יכול להגיש מועמדות — השרת דוחה. זה היה הסיכון, והוא מנוטרל.
- לעקוב 24–48 שעות אחרי לוגי submitFillerInterest ואוסף ה-errors : permission-denied מ-Full Account אמיתי יסמן שהשומר רחב מדי. לא צפוי — אבל זו הבדיקה שתגלה זאת.
- שחרור הגרסה הוא מה שיהפוך את החוויה לנכונה: השער בצד הלקוח מונע את הדחייה מלכתחילה, וה-throw מפסיק את ה"נשלח" השקרי. עד אז אורח מקבל דחייה שהמסך מציג כהצלחה — מכוּעַר, אבל לא מזיק לנתונים.
- Node 20 — דדליין אמיתי בעוד חמישה שבועות. שווה סבב נפרד לפני שהוא חוסם כל פריסת Functions.
- לא לפתוח את שש נקודות ההקשחה הנותרות, את סריקת ה-fillerInterests ואת ניקוי הקוד המת — כולם נדחו במפורש.